

Risk Assessment: Qualitative & Quantitative

Risk definition (again, sharpened)

Risk = Threat (what/who) x Vulnerability (where)
-> Event
-> Impact (business cost)

A risk register captures each identified risk one line: threat, vulnerability, likelihood L, impact I, score, owner, mitigation.

Qualitative scoring (high-medium-low + 1-5)

	Impact →	1 minor	2	3	4	5 severe
L 1 rare	1	2	3	4	5	
... 5 almost certain	5	6	7	8	9	

The matrix is a *communication tool*; the real analysis lives in the register's rationale.

Quantitative (FAIR model)

Asset value (\$) x scenario frequency (per year) x loss magnitude (per event)

Output: annualized loss exposure (ALE) → decision-makers see *money*

Example: "ransomware on billing = 2x/year, \$500k median loss → ALE \$1M; backup-tape mitigation drops ALE to \$300k"

The register discipline

Risk registers live as living documents:
- ID, description, threat, vuln, current controls

- L and I after controls (residual risk)
- Owner, next-review date, mitigation/decision
- status: accept / mitigate / transfer / avoid

Presenting risk

The board wants 3 numbers and one ask, not a 50-row table

Speak in money and likelihood percentages, not 'High' alone

Show *trend*: risk last quarter vs this quarter

Every 'accept' requires explicit sign-off (risk appetite)

Risk management is decision support. A risk register with no owner and no decision is a list – a liability, actually.

[← Module start](#)

[Business Impact Analysis \(BIA\)...](#)